Fundamentals of Cybersecurity

Mohammad Hosseini

Faculty of Computer Science and Engineering
Shahid Beheshti University

Security Toolbox

Part1:

Authentication and access control



Security toolbox

Security professionals have a set of tools they use frequently.

Three key security tools:

- Authentication
- Access control
- Cryptography



Authentication



Authentication

The basis of computer security is **controlled access**:

- *Someone* is authorized to take *some action* on *something*.

But for access control to work, we need to be sure who the someone is.

- Authentication: the process of ascertaining or confirming an identity.

Identification vs. Authentication

Identification

- The act of asserting who a person is.

- Identities are often well known, predictable, or guessable.
- You reveal a part of your identity in many activities.
- Other people could falsely claim to be you by presenting one of your known identifiers.

Authentication

- The act of proving that asserted identity is correct: that the person is who he or she claims.

- Authentication should be private.

Authentication mechanisms

Three qualities to confirm a user's identity:

- Something the user *knows*.
  - Passwords, PINs (personal identification numbers), a secret handshake
- Something the user *is*.
  - Physical characteristic of the user, such as a fingerprint, the pattern of a person's voice, or a face. (biometrics)
- Something the user *has*.
  - Identity badges, physical keys, a driver's license

Authentication based on phrases or facts: something you know

Authentication based on phrases or facts

Password



- Password protection is a relatively secure system for confirming identity-related information, but human practice sometimes degrades its quality.
- How secure are passwords?

Inferring passwords likely for a user

People typically choose **personal passwords**, such as the name of a spouse, child, other family member, or pet,

because that characteristic makes the password easier to remember.

- Many studies have shown that people choose weak and easily guessed passwords more frequently than some might expect.

Dictionary Attack

Several network sites post dictionaries **of phrases**, science fiction character names, places, mythological names, Chinese words, and other specialized lists.

- ➢ Scanning a system for these phrases.



- People think they can be clever by picking a **simple password** and **replacing certain characters**, such as 0 (zero) for letter O, 1 (one) for letter I or L, 3 (three) for letter E or @ (at) for letter A.

  But users are not the only people who could think up these substitutions.

Guessing probable passwords

People often prefer **short passwords** to long ones.

- From the English alphabet there are only $26^1 + 26^2 + 26^3 = 18278$ (not case sensitive) passwords of length 3 or less.

➢ It is easy to write a repetitive password testing application so that a computer can do the guessing.

- At an assumed rate of one password per millisecond, all of these passwords can be checked in 18.278 seconds. (5 characters → 3.5 hours)

Most systems lock out a user who fails a small number of successive login attempts.

- It gives an attacker a way to prevent access by a legitimate user!

Defeating concealment

Easier than guessing a password is just to read it from where it has been stored.

- Obtaining the table gives access to all accounts because it contains not just one but all user IDs and their corresponding passwords.

Identity	Password
Jane	qwerty
Pat	aaaaaa
Phillip	oct31witch
Roz	aaaaaa
Herman	guessme
Claire	aq3wm$oto!4

Operating systems hinder that approach by storing passwords not in their public form but in a **concealed** (obscured) form.

- When a user creates a password, the OS accepts and immediately conceals it, storing the unintelligible version.
- When the user attempts to authenticate by entering a user ID and password, the OS applies the same **concealing function**, and compares the concealed version with what is stored.

Identity	Password
Jane	0x471aa2d2
Pat	0x13b9c32f
Phillip	0x01c142be
Roz	0x13b9c32f
Herman	0x5202aae2
Claire	0x488b8c27

Defeating concealment

The concealing process is one-way

- Converting a password to its concealment form is simple (e.g., encryption), but going the other way (starting with a concealed version and deriving the corresponding password) is effectively impossible.

- However, if the attacker obtains an encrypted password table and learns the concealment algorithm, a computer program can easily test hundreds of thousands of guesses in a matter of minutes.
- The attacker can also make use of a rainbow table: precomputed list of the concealed forms of the common passwords

Original Password	Encrypted Password
asdfg	0x023c94fc
p@55w0rd	0x04ff38d9
aaaaaa	0x13b9c32f
password	0x2129f30d
qwerty	0x471aa2d2
12345678	0x4f2c4dd8
123456	0x5903c34d
aaaaa	0x8384a8c8
	etc.

Defeating concealment

Scrambled passwords have yet another vulnerability.

- Pat and Roz both chose the same password. Both copies will have the same concealed value.

Identity	Password
Jane	qwerty
Pat	aaaaaa
Phillip	oct31witch
Roz	aaaaaa
Herman	guessme
Claire	aq3wm$oto!4

Identity	Password
Jane	0x471aa2d2
Pat	0x13b9c32f
Phillip	0x01c142be
Roz	0x13b9c32f
Herman	0x5202aae2
Claire	0x488b8c27

Defeating concealment

Solution: add an extra piece to the concealment process, called the salt.

- A salt is an extra data field that is different for each user; it can be something related to the user in some way, such as the date its account was created or a part of the user's name.
- The salt value is joined to the password before the combination is transformed by concealment.
  - Pat+aaaaaa has a different concealment value from Roz+aaaaaa.



Identity	ID+password (not stored in table)	Stored Authentication Value
Jane	Jan+qwerty	0x1d46e346
Pat	Pat+aaaaaa	0x2d5d3e44
Phillip	Phi+oct31witch	0xc23c04d8
Roz	Roz+aaaaaa	0xe30f4d27
Herman	Her+guessme	0x8127f48d
Claire	Cla+aq3wm$oto!4	0x5209d942

- Also, an attacker cannot learn anything from a rainbow table because the common passwords now all have a unique component too.

Exhaustive attack

Exhaustive or brute force attack: the attacker tries all possible passwords, usually in some automated fashion.

The number of possible passwords depends on the implementation of the particular password policy and the system implementing it.

- E.g., if passwords are strings consisting of the 26 characters A–Z and can be of any length from 1 to 8 characters, the system has 5×10^{12} possible passwords.
  - a rate of checking one password per millisecond: 150 years
  - one password per microsecond: 2 months
  - If the set of all possible passwords were evenly distributed, an intruder would likely need to try only half of the password space: the expected number of searches to find any particular password.
  - We can lengthen the attacker's search time by allowing numerals (0 through 9) and special characters (such as #, $, and @) to be used in chosen passwords.

Simple practices for security of passwords

- Avoid actual names or words
- Use characters other than just a–z.
- Choose long passwords
- Change the password regularly
- Don't write it down!
- Don't tell anyone else!
  - The easiest attack on sensitive information employs social engineering. For example, the attacker may phone a user, claim to be "system administration," and ask the user to verify the user's password.

Authentication based on biometrics: something you are

Authentication based on biometrics

Biometrics are biological properties, based on some physical characteristic of the human body.

- Fingerprint
- Face
- Iris
- Voice
- Handwriting, signature, hand motion



Authentication based on biometrics

You must first be registered with the system

- the system records the template of your features

When you use a biometric for authentication

- a current set of measurements is taken and compared to the template.
- authentication succeeds if the match is "close enough"

Authentication based on biometrics

Authentication with biometrics has advantages over passwords:

- cannot be lost, stolen, or forgotten
- always available

➢ Some of these characteristics can be forged, but the degree of difficulty is high.

Evaluation of biometric-based authentication

Two kinds of errors:

❖ False positive

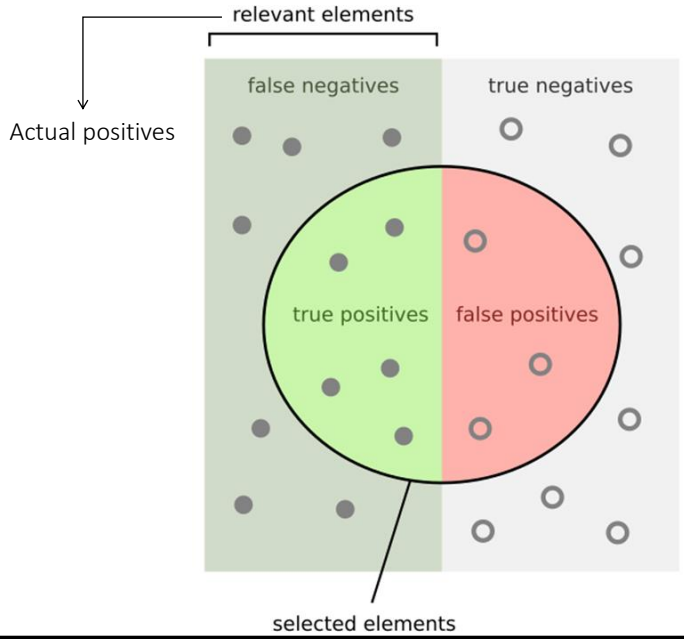
Incorrectly confirming an identity

❖ False negative

Incorrectly denying an identity

Test result ↓ / Actual condition →	is the person claimed	is not the person claimed
Test is positive. (There is a match.)	True Positive (**TP**)	False Positive (**FP**)
Test is negative. (There is no match.)	False Negative (**FN**)	True Negative (**TN**)

Evaluation of biometric-based authentication

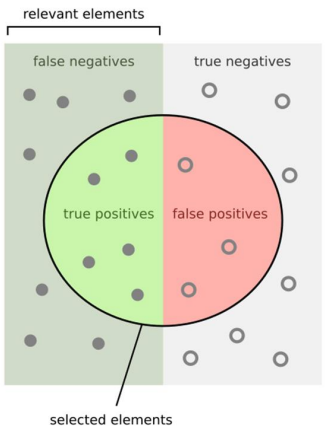


Evaluation metrics

Sensitivity (aka recall, true positive rate)

- A test's ability to designate an actual positive as positive.

$$\frac{TP}{TP + FN}$$



How many relevant items are selected? e.g. How many sick people are correctly identified as having the condition.

Sensitivity= 

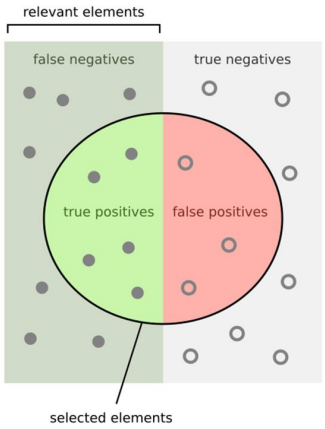
- Reflects the effectiveness in classifying positives.
- A high sensitivity value indicates that the method successfully identifies most of the actual positives, minimizing the number of false negatives.

Evaluation metrics

Specificity (true negative rate)

- A test's ability to designate an actual negative as negative.

$$\frac{TN}{FP + TN}$$



How many negative selected elements are truly negative? e.g. How many healthy people are identified as not having the condition.

Specificity = $\frac{\text{true negatives}}{\text{false positives} + \text{true negatives}}$

- Reflects the effectiveness in classifying negatives.
- A high specificity value indicates that the method successfully classifies most of the actual negatives, minimizing the number of false positive.

Sensitivity vs. Specificity

There is usually a trade-off between sensitivity and specificity, such that higher sensitivities will mean lower specificities and vice versa.

- For a specific authentication algorithm → detection threshold
- You have to find a balance between an acceptable number of false positives and false negatives.

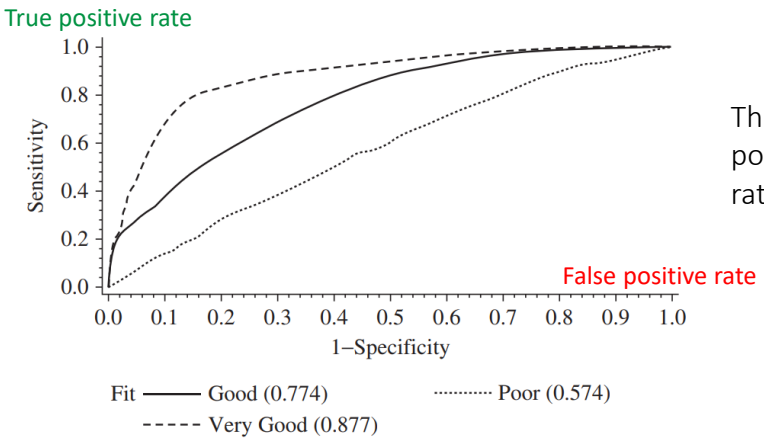
- How does this trade-off affect an authentication system?

Evaluation metrics

- Accuracy (efficacy): $\frac{TP + TN}{TP + FP + TN + FN}$
- Prevalence: $\frac{TP + FN}{TP + FP + TN + FN}$
- Positive predictive value (precision): $\frac{TP}{TP + FP}$
- Negative predictive value: $\frac{TN}{FN + TN}$

How are these two connected to prevalence?

Receiver Operating Characteristic (ROC) curve



The ROC curve is the plot of the true positive rate against the false positive rate **at each threshold setting**.

The accuracy of the test corresponds to the area under the curve.

An area of 1 represents the perfect test, whereas an area of 0.5 is a worthless test.

Challenges of biometric-based authentication

Although we like to think of biometrics as unique parts of an individual, forgeries are possible.

- It has been shown that fingerprint recognition devices can be fooled part of the time by so-called *masterprints*, features common to a number of fingerprints.

Roy, A., et al, "MasterPrint: Exploring the Vulnerability of Partial Fingerprint-Based Authentication Systems." IEEE Transactions on Information Forensics and Security, 2017.

The characteristics can change over time.

➢ Therefore, biometric authentication may be less precise than knowledge-based authentication.

Authentication based on tokens: something you have

Token

Something you have in your possession.

- Key
- Badge
- Identity card
- Tokens that have data to communicate invisibly (credit cards with a magnetic stripe or embedded computer chip, access cards or smartphones with passive or active wireless technology)

Token

Static token: its value remain fixed

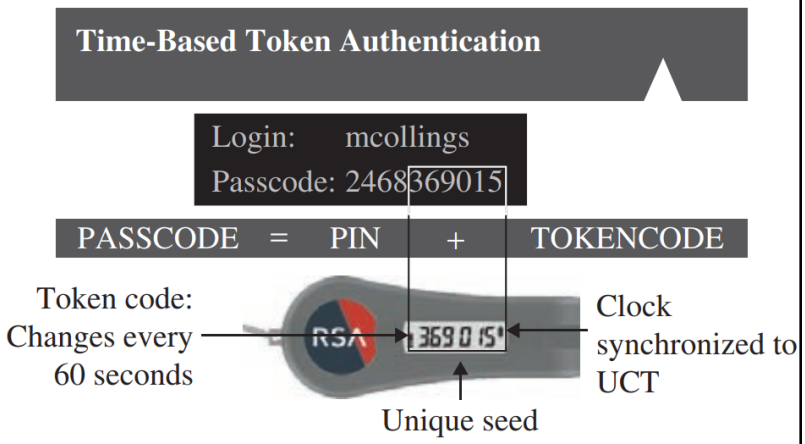
- These authenticators can be easily copied or forged.

Dynamic token: its value changes

- The value will be valid for only one access, and knowing that one value will not allow the outsider to guess or generate the next pass number.

RSA SecurID



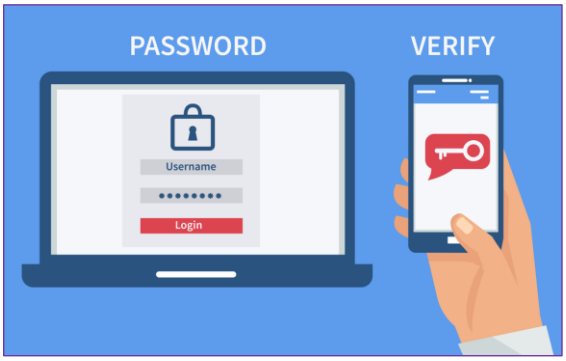


- The token generates a unique, time-sensitive, one-time code at regular intervals, typically every 60 seconds.
- The code is generated using a secret key embedded in the token (unique to each token) and the current timestamp.

Multifactor authentication (MFA)

Multifactor authentication (MFA)

- Requires the user to provide two or more pieces of evidence (verification factors)
- 2FA: two-factor authentication



E.g., the authentication process of some banks: You enter your ID and password (something you know). Then the bank sends a one-time code in a text or email message (something you have).

Single Sign On (SSO)

Remembering identities and distinct passwords for many systems is challenging.

- Single Sign On (SSO): an authentication scheme that allows a user to log in with a single SSO ID to any of several related, yet independent, software systems.
  - SSO allows users to authenticate once and gain access to multiple applications or systems without needing to log in again for each service.
    - It is typically used within a single organization (a security domain).
- Federated Identity Management: extends SSO across multiple organizations or security domains, allowing users to authenticate once and access services from different organizations.
- Example protocols: SAML, OAuth, OpenID Connect, Kerberos

Fitting authentication to the situation

To achieve true security, think carefully about the problem you are trying to solve and the tools you have.

Access Control



Access control

Limiting who can access what in what ways

- A subject is permitted to access an object in a particular mode, and only such authorized accesses are allowed.

Access policies

Access control is a mechanical process, easily implemented by a table and computer process:

- A given subject either can or cannot access a particular object in a specified way.

- Underlying this straightforward process is a complex decision of which accesses should be allowed and under which circumstances.
  - These decisions are based on a security policy.

- Before trying to implement access control, an organization needs to take the time to develop a higher-level security policy, which will then drive all the access control rules.

Effective policy implementation

- Check every access right periodically

- Enforce least privilege
  - A subject should have access to the smallest number of objects necessary to perform some task.
  - Not allowing access to unnecessary objects guards against security weaknesses if a part of the protection mechanism should fail.

- Verify acceptable usage
  - Checking that the activity to be performed on an object is appropriate.

Granularity

The finer the granularity, the larger number of access control decisions that must be made.

- ➢ Performance penalty

- Typically, a file, a program, or a data space is the smallest unit to which access is controlled. However, **applications** can implement their own access control.

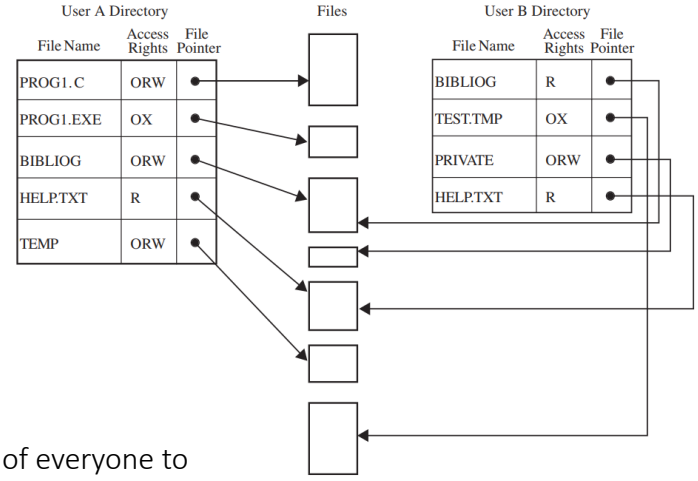
Access log

The access control process should record which accesses have been permitted, creating an audit log (access log).

- ➢ The log is preserved for later analysis:
  - Determining which items have had heavy use.
  - If the system fails, these records can show what accesses were in progress and perhaps help identify the cause of failure.
  - If a user misuses objects, the access log shows exactly which objects the user did access.
  - In the event of an external compromise, the audit log may help identify how the assailant gained access and which data items were accessed (after-the-fact forensic analysis)
- ➢ Granularity matters.

Implementing access control

Problem: protecting files from users of a computing system.



❖ Access Control Directory

- ➢ Each user has a file directory, which lists all the files to which that user has access.
- Simple and easy to implement
- The list becomes too large if many shared objects, such as libraries of subprograms, are accessible to all users.
- If a user wants to remove the rights of everyone to access its file, the operating system must search each individual directory (time consuming on a large system)

Implementing access control

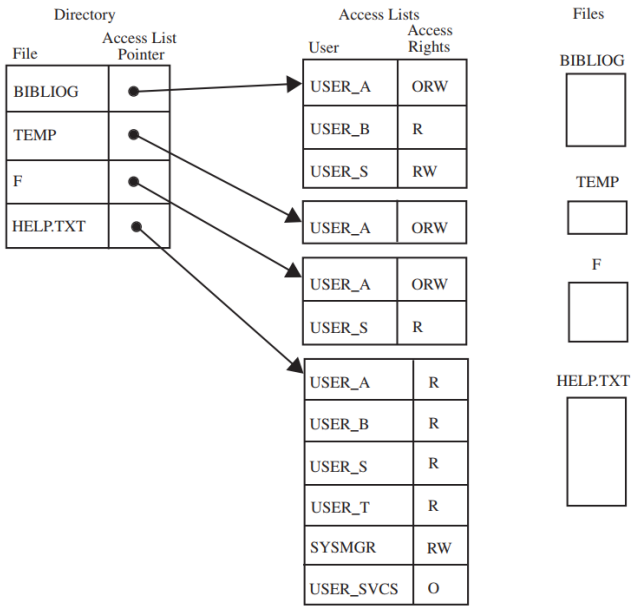
❖ Access Control Matrix

- ➢ A table in which each row represents a subject, each column represents an object, and each entry is the set of access rights for that subject to that object.
- Sparse (most cells are empty)

	Bibliog	Temp	F	Help .txt	C_ Comp	Linker	Clock	Printer
USER A	ORW	ORW	ORW	R	X	X	R	W
USER B	R	–	–	R	X	X	R	W
USER S	RW	–	R	R	X	X	R	W
USER T	–	–	–	R	X	X	R	W
SYS MGR	–	–	–	RW	OX	OX	ORW	O
USER SVCS	–	–	–	O	X	X	R	W

Implementing access control

- Access Control List
  - One access control list per object.
  - The access control list representation can include default rights.



Implementing access control

Unix uses a form of access control list in which each user belongs to three protection classes: **user**, **group**, **world (other)**.

- The access permissions for each object are a triple (*u*,*g*,*w*) in which *u* is for the access rights of the user, *g* is for other members of the group, and *w* is for all other users in the world.
- Wild cards can be used (placeholders that designate "any user", "any group" or "any other".
- The access control list is maintained in sorted order, with * sorted as coming after all specific names.
  - e.g., *UserA-Group1-** would come after all specific compartment designations for *UserA*
- The search for access permission continues just until the first match.
  - All explicit designations are checked before wild cards in any position, so a specific access right would take precedence over a wildcard right.
- *What about revocation?*

Procedure-oriented access control

A procedure that controls access to objects

- The procedure forms a capsule around the object, permitting only certain specified accesses.
- Procedures can ensure that accesses to an object be made through a trusted interface.